Digital Dependencies and Organisational Resilience: An Analytical Grid for Cyber Risk in a Geopolitical Context

Innocent Twagirumukiza · October 2026

Abstract

Background. Cyber risk is still largely framed around the technical perimeter an organisation administers itself. Recent institutional reports and several major incidents show, however, that exposure also stems from resources the organisation does not control: software suppliers, service intermediaries, infrastructure, hardware components and computing capacity.

Purpose. The article asks under what conditions an external dependency becomes a vector for the propagation of cyber risk, including when that risk arises in a geopolitical context, what role the geopolitical dimension plays, and how cyber risk governance can account for it.

Method. A conceptual analysis yields a typology of five categories of dependency and a five-dimension grid (dependency, concentration, substitution, propagation, resilience). The grid is then applied to six situations documented in public sources: NotPetya and Maersk, SolarWinds, the 2015 Ukrainian power grid attack, Change Healthcare, rare earths, and dependencies linked to artificial intelligence. Each case is given an evidence level for its geopolitical dimension.

Findings. Distinguishing the technical security perimeter from the dependency perimeter makes it possible to read very different events together. In the cases examined, the criticality of a dependency appears to be linked more to supply concentration, substitution time and the lack of a degraded mode than to the nature of the actor behind the disruption. A formally established geopolitical link exists for only some of the cases.

Implications. Six orientations are proposed to governance, risk and compliance (GRC) functions, from mapping real dependencies to testing degraded-mode operation and accounting for the AI supply chain.

Limitations. The study relies on public documentary sources, a small number of cases and coding by a single analyst. It provides no original empirical validation.

Keywords: cybersecurity; risk management; digital dependencies; organisational resilience; geopolitics; supply chain; governance; GRC.

1. Introduction

1.1 Context and problem

Most cyber risk management frameworks start from what the organisation administers: workstations, servers, applications, networks, identities, data. The approach is rational, since this is the perimeter on which the organisation can act directly. It becomes insufficient, however, as soon as business continuity depends on resources located outside this perimeter: software published by third parties, infrastructure services, telecommunications operators, payment providers, electronic components, energy.

The strategic context accentuates this limit. In its conclusions of 16 March 2026, the Council of the European Union stresses that malicious cyber activities are often an essential component of broader hybrid campaigns, conducted by state actors or by non-state actors acting as proxies for states (Council of the European Union, 2026, point 12). For its part, ENISA, in its 2026 threat landscape, observes that attacks targeting digital dependencies,

including attacks on the supply chain and on third parties, generally lead to large-scale or high-impact incidents (ENISA, 2026a; ENISA, 2026b). Public administration is the most targeted sector, with 32% of the cases recorded in 2025 (ENISA, 2026b).

It follows that an organisation does not need to be a target in order to be exposed. A company with no particular political or military interest nonetheless belongs to an ecosystem: it relies on a cloud provider, a telecommunications operator, service providers, software developed abroad, an energy supplier, a bank. If one of these actors is attacked, the effects may reach it without it ever having been targeted. The usual question (“am I a target?”) then gives way to another: what does my activity depend on, and who could turn that dependency into a lever?

This shift raises a problem for both research and practice. Work on interdependence and coercion mainly concerns states. Work on supply chains often treats disruptions generically. Cyber risk management frameworks, finally, remain centred on the technical perimeter. These three bodies of work rarely intersect, and none gives a chief information security officer (CISO) a method for deciding which external dependencies deserve particular attention when the geopolitical context deteriorates.

1.2 Research question and contribution

The central question of the article is the following: under what conditions does an external dependency become a vector for the propagation of cyber risk in a geopolitical context, what role does the geopolitical dimension play in it, and how can cyber risk governance account for it? Three sub-questions follow from it. How can a dependency that matters be characterised, as opposed to a mere commercial relationship? Which propagation mechanisms distinguish events of different natures, whether or not they are cyberattacks? What consequences should be drawn for governance, risk and compliance (GRC) functions?

The article makes four contributions. It distinguishes a technical security perimeter from a dependency perimeter. It proposes a typology of five categories of dependency and an analytical grid of five dimensions. It applies this grid to six documented situations, specifying for each the evidence level of the geopolitical link. It derives from this six operational orientations for GRC. The approach is that of a conceptual article: it proceeds by synthesis of the literature and then by confronting the proposed framework with cases (Jaakkola, 2020). It makes no claim to statistical testing.

1.3 Status of statements and outline

The statements in the article do not all have the same status, and the reader must be able to tell them apart. Facts drawn from institutional reports, official documents or audit reports are presented as documented findings. The links drawn between these findings and the geopolitics of dependencies are the author’s interpretation. The recommendations in Section 7 are governance proposals, not empirical conclusions.

The remainder is organised as follows. Section 2 places the article in the literature and the regulatory framework. Section 3 presents the conceptual framework and Section 4 the method. Section 5 analyses six cases; Section 6 compares them and discusses the propositions put forward. Section 7 draws implications for GRC, Section 8 sets out the limitations, and Section 9 concludes.

2. Theoretical framework and literature review

2.1 Interdependence and coercion

Keohane and Nye (1977) showed that asymmetric interdependence is a source of power: whoever can most easily do without the relationship holds leverage over the other. Farrell and Newman (2019) renewed this reasoning by observing that global economic networks (finance, communication, production) are not evenly distributed but organised around central nodes. States exercising authority over these nodes can derive two effects from them: a panopticon effect, which gives access to the information circulating in the network, and a chokepoint effect, which makes it possible to deny an adversary access to the network. Cloud computing platforms, payment systems, software update channels and manufacturers of advanced semiconductors display precisely these characteristics of a central node.

This framework thus supplies the geopolitical mechanism that organisation-centred approaches lack. It has, however, a limit for our purposes: it describes the strategy of states, not the position of the downstream organisation, which bears the exercise of a lever or its collateral effects.

2.2 Cyber, conflict and hybrid threats

Rid (2012) argued that most cyber operations amount to sabotage, espionage and subversion rather than war in the strict sense. Buchanan (2017) described a security dilemma specific to cyberspace: an intrusion with a defensive or intelligence purpose can be read as preparation for an attack, which fuels escalation. Recent institutional documents extend these analyses. The Council of the European Union recalls that hybrid threats often combine varied means, including information manipulation and interference, cyberattacks, economic coercion, diplomatic coercion and threats of military force, and that they are designed to remain below the threshold of what would be perceived as an act of war (Council of the European Union, 2026).

The objectives of an operation are therefore not limited to data theft or ransom. They may include gathering intelligence, preparing a future operation, destabilising a sector, disrupting a service, testing a capability, applying pressure, influencing opinion or producing an economic effect. A difficulty of interpretation is added: ransomware may pursue a financial goal, a denial-of-service attack may come from hacktivists, an espionage operation from a state actor, and these categories overlap. For an organisation, attribution is rarely available at the moment a decision has to be made.

2.3 Systemic risk and supply chains

Perrow (1984) showed that systems that are both complex and tightly coupled produce accidents that their operators can neither anticipate nor stop in time. Contemporary digital chains display both properties. The supply chain literature has drawn from this the notion of vulnerability: Christopher and Peck (2004) associate resilience with visibility, flexibility and collaboration between actors, while Sheffi (2005) stresses the hidden cost of concentration on a small number of suppliers.

The digital domain adds a specificity. The trust relationship (a signed update, a monitoring tool with extended privileges) itself becomes a component of risk. ENISA notes, moreover, that digital dependencies widen the attack surface and call for a new level of vigilance (ENISA, 2026b). The EU toolbox for ICT supply chain security, adopted on 13 February 2026 by the NIS Cooperation Group, proposes a common approach to identify, assess and mitigate these risks, including those arising from dependence on high-risk suppliers (European Commission / NIS Cooperation Group, 2026).

2.4 Organisational resilience

In resilience engineering, resilience denotes the capacity of a system to adjust its functioning before, during and after a disturbance so as to sustain required operations (Hollnagel et al., 2006). NIST breaks cyber resilience down into four objectives: anticipate, withstand, recover, adapt (Ross et al., 2021). The ISO 22301 standard (2019) organises business continuity around impact analysis and recovery strategies.

These frameworks provide solid instruments, but they are addressed first of all to the systems and processes that the organisation controls. The failure of a third party generally appears in them as one scenario among others in an impact analysis, rather than as an object of analysis in its own right.

2.5 European regulatory framework

The NIS2 Directive (2022/2555) requires the entities concerned to adopt risk management measures covering supply chain security, including relationships with direct suppliers (Art. 21), and provides at Union level for coordinated risk assessments of critical supply chains (Art. 22). The DORA Regulation (2022/2554) goes further for the financial sector: it governs the risk arising from ICT service providers, requires the assessment of concentration risk and provides for exit strategies. The Cyber Resilience Act (2024/2847) requires manufacturers to exercise due diligence regarding third-party components integrated into their products. The Artificial Intelligence Act (2024/1689) allocates obligations between providers and deployers, which makes the AI value chain an object of compliance. The ISO/IEC 27001:2022 and ISO/IEC 27036 standards, for their part, address supplier relationships.

These texts have one point in common: they require that third-party risks be identified and addressed. They leave it to the organisation, however, to define how, and the dominant practice remains the compliance questionnaire supplemented by a register of providers. Substitution time, the holding of degraded mode and exposure to political decisions do not appear in them as explicit criteria, or only in part (DORA).

2.6 Identified gap

Three discourses thus coexist without meeting. Interdependence theory explains how states exploit network nodes, but does not descend to the level of the organisation. The supply chain literature analyses the vulnerability of organisations, but without a mechanism of geopolitical coercion. Cyber risk management frameworks equip decision-making, but around a technical perimeter. The article positions itself at their intersection: it seeks to translate, at the level of the organisation, what weaponised interdependence does to digital and material dependencies.

3. Conceptual framework

3.1 Technical security perimeter and dependency perimeter

Cyber risk analysis is most often organised around the assets that the organisation administers directly. We call *technical security perimeter* the set of systems and assets over which it can itself apply protective measures. We call *dependency perimeter* the set of resources and actors whose unavailability or compromise may prevent it from fulfilling its missions. The two perimeters partly overlap without coinciding. A cloud provider may belong to the second without belonging to the first, and a workstation belongs to the first without necessarily appearing in the second, if it supports no essential function.

The distinction changes the question put to the risk manager. It is no longer only a matter of knowing whether what one administers is protected, but of understanding what allows the organisation to function and what could prevent it from doing so. It extends the intuition underlying business impact analysis, while applying it to resources that the organisation controls neither technically, nor legally, nor sometimes geographically.

3.2 From dependency to criticality

A dependency is not a vulnerability. Almost every organisation depends on suppliers, and this interconnection is the ordinary condition of the digital economy. A dependency becomes a strategic risk factor when several conditions accumulate: strong supply concentration, difficulty of substitution, a long replacement time, weak mastery of the technology, and exposure to political decisions or international tensions. The first three are structural, the fourth depends on the organisation, the last on the context. We use *criticality* to denote the degree to which these conditions are met for a given dependency.

This clarification has a methodological consequence. A supplier's nationality is not enough to measure geopolitical exposure, which must rest on observable factors (see 3.4).

3.3 Typology of dependencies

We distinguish five categories, defined by the nature of the resource on which the organisation depends (Table 1).

Category	Resource the organisation depends on	Typical failure mode	Possible geopolitical lever
Software	Third-party software, updates, monitoring tools	Compromise of the distribution chain, loss of integrity	State operation against a vendor, legal constraints weighing on it
Industrial (OT)	Control systems and connected technical equipment	Loss of control, shutdown or degradation of a physical service	Sabotage of essential infrastructure
Service intermediary	A sector's central provider (payment, processing, shared infrastructure)	Simultaneous unavailability of otherwise independent organisations	Pressure on a central node, collateral effect of a conflict
Hardware	Raw materials, components, manufacturing capacity	Supply disruption or restriction	Export restrictions, sanctions
Algorithmic	AI models, computing power, data, associated services	Loss of access, model tampering, service unavailability	Export controls on computing components, applicable jurisdiction

The refrigeration control systems of a chain of stores provide an example of an industrial dependency at the scenario stage. A single technology deployed across several sites creates a common dependency, and obsolescence, insufficient maintenance or the absence of a backup solution can produce a simultaneous failure. In the absence of a documented incident, we do not retain this scenario among the cases of Section 5. It merely illustrates the category.

3.4 Analytical grid

The grid comprises five dimensions (Table 2). Each corresponds to a question that the risk manager can ask about a given dependency. The first four dimensions measure an exposure: the higher the level, the more exposed the organisation. The fifth describes a capacity: the stronger it is, the more contained the exposure. The thresholds proposed for substitution distinguish three orders of magnitude: operational recovery (days), reconfiguration (weeks to a few months) and structural replacement (more than three months). They are indicative, reflect a choice by the author, and will need to be calibrated by sector, for example from the recovery time objectives of impact analyses.

Dimension	Question	Observable indicators	Reading
Dependency	Which external resources are indispensable to our activities?	Mapping of essential functions and the resources that support them, contracts, flows	Low, moderate or high exposure
Concentration	Do several critical functions rely on the same supplier, the same technology or the same geographical area?	Share of a provider or technology in essential functions, market concentration, location	Low, moderate or high exposure
Substitution	How long would it take to replace an unavailable resource?	Estimated replacement time, migration cost, existence of a qualified alternative	Low (under one week), moderate (one week to three months), high (over three months) exposure
Propagation	Which activities, subsidiaries, infrastructure or partners would be affected?	Number of dependent functions and entities, interconnections	Low, moderate or high exposure
Resilience	Which functions can be maintained in degraded mode, for how long, and with what means?	Existence and testing of degraded procedures, duration of autonomy, alternative means	Low, partial or strong capacity

The geopolitical dimension does not enter the grid as one more score. It is read through observable factors: trade restrictions, diplomatic tensions, industrial concentration, dependence on infrastructure located abroad, legal constraints, the possibility of sanctions, difficulties of access to maintenance services. For the cases studied, it is recorded separately, in the form of an evidence level defined in 4.4.

3.5 Propositions

The framework leads to three propositions, which Section 6 confronts with the cases. They are formulated as working hypotheses: P1 and P3 are close to intuition and serve mainly to check that the grid orders the cases correctly, whereas P2, which sets the state character of the actor against the structural position of the dependency, is the most discriminating.

P1. The criticality of a dependency increases with supply concentration and with substitution time, whatever the nature, cyber or otherwise, of the event that reveals it.

P2. The severity of the impact on an organisation depends less on the state character of the actor behind the disruption than on the place the dependency occupies in the architecture of essential functions, particularly when it comes with extended privileges or a central position in a sector.

P3. The capacity to operate in degraded mode moderates the relationship between the unavailability of a resource and the loss of function: the stronger it is, the more limited the duration of the loss.

4. Methodology

4.1 Research design

The article combines a conceptual construction (Section 3) and a multiple case study (Section 5), qualitative and documentary. The choice reflects the nature of the question: the aim is less to measure the frequency of a phenomenon than to test the capacity of a framework to make events of different natures intelligible. The cases therefore serve to explore and discuss the framework, not to test it statistically. The generalisation sought is analytical rather than statistical, in the sense of Yin (2018). The logic of theory building from cases follows Eisenhardt (1989).

4.2 Case selection criteria

Selection is information-oriented rather than guided by representativeness, following a logic of maximum variation (Flyvbjerg, 2006). A case is retained if it meets five conditions: the event is documented by at least one institutional or primary source; it had demonstrated effects on the business continuity of organisations; it involves a type of dependency different from the other cases; it varies by the nature of the actor involved (state, criminal, public decision); and the corpus includes at least one case outside the strictly cyber field, in order to verify whether the framework extends to other forms of dependency.

Six situations meet these criteria: NotPetya and Maersk (2017), SolarWinds (2020), the attack on the Ukrainian power grid (2015), Change Healthcare (2024), restrictions on rare earths (2025) and dependencies linked to artificial intelligence. This last case is prospective: it does not rest on a documented incident and is treated as such. The refrigeration systems scenario, lacking a sourced incident, is excluded from the corpus.

4.3 Sources

The corpus draws on reports from public agencies and European institutions, regulatory texts, official attribution statements, corporate annual reports and public audit reports. Primary sources are preferred. The specialised press is used only for factual elements absent from the other sources, and is then identified as such. Every factual claim in the text refers to a source in the reference list.

4.4 Coding

Each case is analysed along the five dimensions of the grid (3.4). The first four receive an exposure level (low, moderate, high), the fifth a capacity level (low, partial, strong). The coding is qualitative; it is argued in the text of each case and justified dimension by dimension in Appendix D.

The geopolitical dimension is treated separately, through an evidence level with four positions. Level A denotes an official state attribution or a documented indictment. Level B corresponds to a documented geopolitical context without shared formal attribution. Level C signals a documented systemic impact with no established geopolitical link. Level D applies to a disruption resulting from a public decision or policy that is not a cyber operation. This separation avoids presuming a geopolitical dimension where it has not been demonstrated, and denying it where it has.

4.5 Validity and bias

Construct validity rests on the triangulation of sources and on the explicit distinction between facts, interpretations and propositions. The likely biases are of three kinds. The availability of documentation favours large-scale and heavily commented incidents. Hindsight tends to make the sequence of causes more legible than it was for the actors. Finally, the coding was carried out by a single analyst, which limits inter-coder reliability. Section 8 returns to these limitations.

5. Case analysis

5.1 NotPetya and Maersk (2017)

The NotPetya incident of June 2017 offers a clear example of risk propagating beyond the organisation initially exposed. The malicious software spread internationally after being introduced into a software distribution chain used in Ukraine. A. P. Moller-Maersk, a shipping and logistics group, confirmed that its systems had been affected and its operations disrupted. In its 2017 annual report, the company estimates the impact of the attack at between

250 and 300 million dollars, concentrated on Maersk Line (A. P. Moller-Maersk, 2018). Detailed journalistic accounts report that the rebuilding of the network depended in part on a copy of a domain controller preserved almost by chance (Greenberg, 2018).

The dependency at play is software-based: the trust placed in an update channel. The interest of the case lies less in the extent of the IT damage than in the way a software compromise reached a company whose operations rely on the coordination of digital systems, port facilities, flows of goods and partners. The internal disruption spread to physical operations, customers and business partners: an IT incident became an economic continuity problem.

The geopolitical dimension is established. The British and American authorities publicly attributed NotPetya to the Russian military on 15 February 2018 (The White House, 2018), and the 2020 indictment of Russian military intelligence officers linked the operation to them (U.S. Department of Justice, 2020). The case falls under level A. It shows that an action conducted in a regional context can produce economic effects well beyond its initial theatre.

Reading through the grid: dependency is high, concentration moderate (widespread but local software), substitution moderate (the accounting software is itself replaceable; it was the rebuilding of the IT estate, of the order of a few days to a few weeks according to available accounts, that conditioned recovery), propagation high and resilience low, recovery having owed to partly fortuitous circumstances. For the organisation, the lesson is that it must be able to contain the effects of an attack that did not necessarily target it in the first place.

5.2 SolarWinds (2020)

The compromise of SolarWinds' Orion monitoring platform, revealed in December 2020, illustrates another form of dependency: one that rests on the trust placed in software tools and their update mechanisms. Legitimate versions of the software had been altered to embed the SUNBURST malicious code. The updates distributed to customers thus served as an intrusion vector. According to the vendor, which had notified approximately 33,000 Orion customers, fewer than 18,000 customers are believed to have installed a version containing the malicious code (SolarWinds Corporation, 2020). CERT-FR documented the incident and recommended that the organisations concerned check their versions, look for signs of compromise and take into account the risk weighing on the environments administered by the platform (CERT-FR, 2020). The American CISA, for its part, ordered federal agencies to disconnect the affected Orion products (CISA, 2020).

The problem goes beyond a product's vulnerability. A monitoring tool has extensive visibility over the infrastructure it administers. The trust placed in it and the privileges assigned to it make it an entry point to sensitive resources. The case shows that a supplier's compliance, the legitimacy of an update and a vendor's reputation are not enough to guarantee the integrity of a software chain: the trust relationship is itself a component of risk.

The American authorities formally attributed the operation to the Russian foreign intelligence service (SVR) in April 2021, judging that the compromise of the software chain gave it the capacity to spy on or disrupt more than 16,000 computer systems worldwide (The White House, 2021; CISA, 2020): level A.

Reading through the grid: high dependency, high concentration (a platform present at a very large number of customers, with extended privileges), high substitution (replacing a monitoring tool is a project of several months), high propagation, low resilience, detection having been late. An organisation's security cannot rest exclusively on the trust placed in the components on which it depends.

5.3 The Ukrainian power grid (2015)

The December 2015 attack on electricity distribution operators in Ukraine is a central case for understanding the physical consequences of a digital operation. The outages affected approximately 225,000 customers for several hours, up to about six hours according to analyses. The attackers, who held legitimate credentials, took control of command interfaces to cause the interruptions, then wiped systems using the KillDisk software, which complicated remote recovery and forced operators to switch to manual mode (CISA, 2016; Lee et al., 2016).

The case highlights the interdependence between information systems, operational technologies and the essential functions of a territory. The unavailability of a control system does not simply translate into data loss or an application outage: it can directly affect the distribution of an indispensable resource. Civilian infrastructure can therefore be targeted in a context of confrontation and become an instrument of strategic pressure.

The evidence level is A, on the basis of the 2020 American indictment, which charges Russian military intelligence officers for the attacks on the Ukrainian grid (U.S. Department of Justice, 2020). The alert published in 2016 describes the attack and its mechanisms without, to our knowledge, naming its perpetrator (CISA, 2016): attribution therefore rests on the indictment alone.

Reading through the grid: high dependency, moderate concentration (three distributors with similar architectures), moderate substitution (power was restored within hours through manual operation, but restoring the digital control systems took much longer; manual operation belongs to resilience, not to substitution), moderate propagation, partial resilience. This last point deserves emphasis: the relatively short duration of the interruptions owes to the manual recovery procedures that the operators had retained. Protecting a critical infrastructure means preserving its capacity to deliver a service even when its digital systems are compromised.

5.4 Change Healthcare (2024)

The ransomware cyberattack suffered by Change Healthcare in February 2024 shows the consequences of a strong dependency on a digital intermediary in an essential sector. This American provider is involved in particular in the processing of payments and administrative operations related to healthcare. According to the Government Accountability Office, the attack, which included data theft, led to estimated losses of 874 million dollars and wide-ranging repercussions for care providers and patient care (U.S. GAO, 2024). This figure is only a snapshot: for 2024, the parent company UnitedHealth Group reports direct response costs exceeding two billion dollars, excluding business losses, and a loan programme for care providers of more than nine billion dollars (UnitedHealth Group, 2025).

This case reveals a concentration risk. When a provider occupies a central position in the functioning of a sector, its unavailability can simultaneously affect organisations that remain legally and operationally independent. Each may have its own cybersecurity arrangements and yet find itself facing the same point of failure.

The systemic impact must nevertheless be distinguished from strategic intent. This was a ransomware attack, and no public evidence links it, to our knowledge, to a state strategy (U.S. GAO, 2024). It demonstrates the consequences of a centralised dependency, but it is not sufficient to establish a state destabilisation operation: level C.

Reading through the grid: high dependency, high concentration, high substitution, high propagation, low resilience. The case is valuable for proposition P2: it produces a considerable sectoral impact without a proven state actor.

5.5 Rare earths (2025)

The geopolitics of dependencies is not limited to software and networks. It also concerns the materials and components needed to manufacture contemporary technologies. According to the International Energy Agency, China accounted in 2024 for about 60% of global mine production of the rare earths used in magnets, 91% of their refined production and 94% of the world's manufacturing of the sintered permanent magnets concerned (IEA, 2025). Strategic dependency thus results not only from geological availability, but also from the concentration of industrial processing capacity.

The export controls introduced by China on 4 April 2025 on seven heavy rare earths, their compounds and the corresponding magnets showed the possible consequences of this concentration. The IEA indicates that car manufacturers in Europe, the United States and elsewhere encountered supply difficulties, some reducing their utilisation rate or temporarily suspending plants. Broader controls, announced on 9 October 2025, now also target parts, components and assemblies containing rare earths of Chinese origin (IEA, 2025).

This case is not a cyberattack. It nonetheless broadens the analysis: an organisation may have a properly secured digital infrastructure and remain vulnerable to an external decision that cuts off access to an indispensable component. The evidence level is D, since the disruption results from a public decision.

Reading through the grid: high dependency, high concentration, high substitution, high propagation, partial resilience, some of the companies concerned having been able to adjust their production without halting it completely.

5.6 Artificial intelligence and computing dependencies (prospective case)

The development of advanced AI systems rests on interdependent resources: specialised semiconductors, computing infrastructure, data centres, energy, training data, models, scientific expertise and cloud computing services. Control of them is unevenly distributed between states and industrial actors. An organisation may own its data and define its security policies while depending on an external provider to access a model, run processing or maintain an essential service.

AI also transforms the threat landscape. ENISA observes a growing use of AI by malicious groups, mainly to facilitate or amplify their activities, and notes that the integration of AI systems into professional environments widens the attack surface: these systems are both tools and targets (ENISA, 2025; ENISA, 2026b). NIST has, moreover, formalised the categories of attacks against machine learning systems: evasion, poisoning and privacy attacks for predictive AI, to which are added, for generative AI, supply chain attacks, prompt injection and misuse (Vassilev et al., 2025). Export restrictions on advanced computing technologies finally show that the components needed for AI have become instruments of national security policy. The so-called AI diffusion framework, published in January 2025 (U.S. Department of Commerce / BIS, 2025), was however announced as rescinded by BIS in May 2025, before it took effect, and its replacement had still not been published by mid-2026, the earlier controls on advanced chips remaining in force (Miller & Chevalier, 2026). This instability itself illustrates the shifting nature of these levers.

This case differs from the previous ones: it does not rest on a documented incident of massive disruption. It is retained because the structure of dependency is visible in it before any crisis, which makes it possible to test the grid preventively. The question becomes: what does our AI depend on? Model, cloud, data, programming interfaces, infrastructure, vendor, graphics processors, software chain. Would a forty-eight-hour unavailability of a model provider be bearable for the functions that rely on it?

Reading through the grid: the coding is indicative: moderate to high dependency depending on the organisation, high concentration, high substitution, moderate propagation, resilience to be documented. The evidence level is D, for the computing layer.

6. Synthesis and discussion

6.1 Comparative synthesis

Table 3 reproduces the coding of each case. The first four dimensions express an exposure, the fifth a capacity, and the last column the geopolitical evidence level defined in 4.4. The coding is the author's, justified in Appendix D, and remains open to argument.

Case	Category	Dependency	Concentration	Substitution	Propagation	Resilience	Geopol. evidence
NotPetya / Maersk (2017)	Software	High	Moderate	Moderate	High	Low	A
SolarWinds (2020)	Software	High	High	High	High	Low	A
Ukrainian grid (2015)	Industrial (OT)	High	Moderate	Moderate	Moderate	Partial	A
Change Healthcare (2024)	Service intermediary	High	High	High	High	Low	C
Rare earths (2025)	Hardware	High	High	High	High	Partial	D
AI and computing (prospective)	Algorithmic	Moderate to high	High	High	Moderate	To be documented	D

6.2 Cross-cutting findings

Three findings emerge. The first is that a dependency becomes particularly sensitive when it is hard to replace and conditions an essential function. The cases where concentration and difficulty of substitution are both high (SolarWinds, Change Healthcare, rare earths) are also those where the effect spreads across a sector or a set of organisations rather than a single one.

The second is that interconnection amplifies the consequences of an incident beyond its point of origin. NotPetya hits a logistics company by way of Ukrainian tax software, and Change Healthcare reaches healthcare actors that have no link with one another other than the same intermediary.

The third is that vulnerabilities can arise just as well from a cyberattack as from industrial concentration or from a commercial or political decision. Putting a ransomware attack and an export restriction on the same plane only makes sense if their different statuses are kept in mind, which the geopolitical evidence level makes explicit.

6.3 Return to the propositions

Since the coding was carried out by the author using the grid itself, the agreement noted below checks the internal consistency of the framework more than it validates it: P1 and P3 are close to intuition, and P2 is the most discriminating proposition.

P1 is consistent with the cases. Situations of high concentration and high substitution (SolarWinds, Change Healthcare, rare earths) are those with the widest reach, whereas the Ukrainian case, where concentration, substitution and propagation are moderate, remains confined to three distributors. The proposition holds across the boundary between cyber and non-cyber events, since the rare earths case confirms it without any cyberattack.

P2 is consistent with the cases. Change Healthcare produces a considerable sectoral impact without a proven state actor, whereas the Ukrainian attack, attributed to a state actor, had a limited duration. What differentiates the situations owes more to the place of the dependency in the architecture of functions and to its privileges (SolarWinds) than to the attacker's identity. The nature of the actor does, however, modify other parameters, such as the probability of deliberate targeting or the duration of a restriction, which the present corpus does not allow us to assess.

P3 is also supported. The Ukrainian case, where operators kept manual procedures, shows interruptions of a few hours; Maersk, whose recovery owed to partly fortuitous circumstances, suffers a deeper disruption. In the rare earths case, some manufacturers were able to reduce production rather than stop it. These comparisons remain indications. They do not constitute a test, and other factors intervene in each case.

6.4 Contribution relative to existing frameworks

The grid does not claim to invent its notions: concentration, substitution time and exit strategies already exist, separately, in ISO 22301, in DORA and in the supply chain literature. Its contribution is to articulate them in a single grid, applicable to dependencies of different natures. It replaces neither the impact analysis of ISO 22301 nor the supplier requirements of NIS2 and DORA. It complements them on three points. It makes substitution time and degraded mode explicit and comparable criteria, where the texts merely require that risks be addressed. It treats hardware dependency and algorithmic dependency within the same framework as digital dependency. Finally, it proposes to read geopolitical exposure from observable factors rather than from suppliers' nationality.

6.5 What geopolitics adds, and what it does not explain

A formally established geopolitical link exists for only three of the five cases observed (level A), the sixth being prospective. In the others, the geopolitical dimension is either absent (level C) or indirect (level D). This finding calls for caution: the framework does not demonstrate that every critical dependency is a geopolitical instrument. It shows that a critical dependency is a vector of propagation whatever the origin of the disruption, and that geopolitics acts mainly as a modulator: it increases the probability of targeting, it may lengthen the duration of a restriction, it may complicate access to maintenance or updates. This is why the geopolitical reading should remain a layer of analysis added to the grid, not a criterion that replaces it.

7. Implications for GRC

The proposals that follow are governance recommendations formulated by the author on the basis of the preceding analysis. They are not empirical conclusions.

7.1 Map real dependencies

The annual compliance questionnaire remains useful, but it describes what the supplier declares, not what the organisation depends on. The first step is to start from essential functions and work back to the resources that support them, including second-tier subcontractors and hardware components. This mapping directly feeds the dependency, concentration and propagation dimensions of the grid.

7.2 Integrate the geopolitical dimension into supplier analysis

Geopolitics should not be reduced to an indicator based on the supplier's nationality. It benefits from resting on observable factors: trade restrictions, diplomatic tensions, industrial concentration, dependence on infrastructure located abroad, legal constraints, the possibility of sanctions, difficulties of access to maintenance. These factors

are recorded as a distinct layer of analysis, revisable as the context evolves.

7.3 Test degraded-mode operation

No organisation can reasonably assume that it will prevent all attacks. It is therefore necessary to know how long it can operate if a critical supplier becomes unavailable. Exercises covering durations of forty-eight hours, one week and one month make it possible to distinguish the functions that hold from those that stop, and to feed the resilience dimension. The Ukrainian case is a reminder of the value of manual procedures that are kept and maintained.

7.4 Extend the scope of business continuity

Continuity plans ordinarily deal with internal failures and physical disasters. They must integrate external digital dependencies as scenarios in their own right, with an estimated substitution time and a fallback plan, rather than as an implicit assumption.

7.5 Treat AI and its supply chain as a domain of dependency

The AI services used in processes (model, cloud, data, interfaces, vendor) must appear in the mapping, with the same questions as for any other dependency, to which is added the examination of the obligations that the European AI regulation places on providers and deployers.

7.6 Bring functions together at the level of risk governance

The evolution described does not mean that the CISO should take the place of those responsible for procurement, operations, continuity or economic intelligence. It requires cross-functional governance, capable of linking technical, contractual, industrial and geopolitical risks. The grid of Section 3 can serve as a common language: five simple questions that each function can address in its own domain.

A fictional illustration shows how the approach is used. Consider a regional distributor whose cold chain relies on a single monitoring system, hosted by a provider. The grid yields high dependency, high concentration, moderate to high substitution (a migration would take several weeks), high propagation (all sites) and low resilience, for lack of a manual temperature-logging procedure. The response is not necessarily to change provider. It may consist in documenting a degraded mode (manual readings, buffer stocks, a backup agreement) and testing a forty-eight-hour unavailability. The decision remains a governance decision: to reduce, diversify, monitor or offset the dependency, with full knowledge of the facts. Resilience does not consist in eliminating all dependencies, but in identifying those that could compromise essential functions.

8. Limitations and research directions

8.1 Limitations

This study has several limitations. The corpus is small: six situations, chosen for their variety rather than their representativeness, allow no statistical generalisation. The sources are documentary and of uneven quality. A corporate annual report or a public audit estimate does not provide comparable measures, and several of the amounts cited are dated estimates. The coding was carried out by a single analyst, without double coding, and the thresholds of the substitution dimension are indicative. The AI case is prospective: it does not rest on an incident and its coding remains provisional. No validation with practitioners has been carried out. Finally, the subject evolves quickly, and some recent sources may be clarified or revised.

To these are added the biases already mentioned in 4.5: the abundant documentation of major incidents, which may give a more spectacular picture than the average, and hindsight.

8.2 Research directions

Four extensions seem natural. The first is validation through semi-structured interviews with CISOs and risk managers, in order to test the legibility and usefulness of the grid. The second is a Delphi-type approach to calibrate the substitution thresholds by sector. The third is independent double coding of the cases, which would make it possible to estimate inter-coder reliability. The fourth is a sectoral application (healthcare, energy, finance), possibly in the form of an anonymised internal case study, linking the grid to the provider registers required by DORA or to existing impact analyses.

9. Conclusion

This article starts from a simple observation: protecting the information system no longer suffices to describe what an organisation depends on in order to function. It proposes to distinguish a technical security perimeter from a dependency perimeter, to classify dependencies into five categories and to examine them through five questions: dependency, concentration, substitution, propagation, resilience. Applied to six situations, this grid makes it possible to bring together very different events, from a state operation against a software chain to an export restriction on materials.

The cases suggest that the criticality of a dependency stems first from supply concentration, the difficulty of replacing it and the absence of a degraded mode. The role of geopolitics in them is real but indirect: it modifies the probability and duration of a disruption without being its sole cause. This conclusion is a working hypothesis supported by cases, not a demonstrated result, and it calls for the validations described in 8.2.

For governance, risk and compliance functions, the consequence is practical. It is a matter of mapping what the activity really depends on, testing what happens when a resource is missing, and deciding with full knowledge of the facts which dependencies to reduce, diversify, monitor or offset. Cyber resilience does not consist only in preventing the crisis from entering the organisation. It also requires being able to keep functioning when the crisis is already there.

References

A. P. Moller-Maersk. (2018). *Annual Report 2017*. https://www.maersk.com/

Buchanan, B. (2017). *The cybersecurity dilemma: Hacking, trust and fear between nations*. Oxford University Press.

CERT-FR. (2020, updated 2021). *Présence de code malveillant dans SolarWinds Orion* (Alert CERTFR-2020-ALE-026). https://www.cert.ssi.gouv.fr/

Christopher, M., & Peck, H. (2004). Building the resilient supply chain. *The International Journal of Logistics Management, 15*(2), 1-14.

CISA. (2016). *Cyber-attack against Ukrainian critical infrastructure* (Alert IR-ALERT-H-16-056-01). https://www.cisa.gov/

CISA. (2020, December 13). *Emergency Directive 21-01: Mitigate SolarWinds Orion code compromise*. https://www.cisa.gov/

Council of the European Union. (2026, March 16). *Council adopts conclusions on advancing the EU's capacity to counter hybrid threats* (Press release 192/26).

Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 (NIS 2 Directive). *Official Journal of the European Union*, L 333, 27 December 2022.

Eisenhardt, K. M. (1989). Building theories from case study research. *Academy of Management Review, 14*(4), 532-550.

ENISA. (2025, October 1). *ENISA Threat Landscape 2025*. European Union Agency for Cybersecurity.

ENISA. (2026a, September 22). *ENISA Threat Landscape 2026*.

ENISA. (2026b, September 22). *Exploring the evolution of the cyber threat landscape* [Press release].

European Commission / NIS Cooperation Group. (2026, February 13). *Toolbox to improve ICT supply chain security*.

Farrell, H., & Newman, A. L. (2019). Weaponized interdependence. *International Security, 44*(1), 42-79.

Flyvbjerg, B. (2006). Five misunderstandings about case-study research. *Qualitative Inquiry, 12*(2), 219-245.

Greenberg, A. (2018, August 22). The untold story of NotPetya. *Wired*.

Hollnagel, E., Woods, D. D., & Leveson, N. (Eds.). (2006). *Resilience engineering: Concepts and precepts*. Ashgate.

International Energy Agency. (2025). *With new export controls on critical minerals*. https://www.iea.org/

ISO. (2019). *ISO 22301:2019 Security and resilience: Business continuity management systems*.

ISO/IEC. (2022). *ISO/IEC 27001:2022*.

ISO/IEC. (2021). ISO/IEC 27036-1:2021.

Jaakkola, E. (2020). Designing conceptual articles. *AMS Review, 10*, 18-26.

Keohane, R. O., & Nye, J. S. (1977). *Power and interdependence*. Little, Brown.

Lee, R. M., Assante, M. J., & Conway, T. (2016). *Analysis of the cyber attack on the Ukrainian power grid*. SANS ICS / E-ISAC.

Miller & Chevalier. (2026, August 12). *BIS export controls 2025 year-in-review and 2026 mid-year update*. https://www.millerchevalier.com/publication/bis-export-controls-2025-year-review-and-2026-mid-year-update

Perrow, C. (1984). Normal accidents. Basic Books.

Regulation (EU) 2022/2554 (DORA). *Official Journal of the European Union*, L 333, 27 December 2022.

Regulation (EU) 2024/1689 (AI Act). *Official Journal of the European Union*, L, 12 July 2024.

Regulation (EU) 2024/2847 (Cyber Resilience Act). *Official Journal of the European Union*, L, 20 November 2024.

Rid, T. (2012). Cyber war will not take place. *Journal of Strategic Studies, 35*(1), 5-32.

Ross, R., et al. (2021). *Developing cyber-resilient systems* (NIST SP 800-160 Vol. 2 Rev. 1). NIST.

Sheffi, Y. (2005). *The resilient enterprise*. MIT Press.

SolarWinds Corporation. (2020, December 14). *Form 8-K*. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm

The White House. (2018, February 15). Statement from the Press Secretary.

The White House. (2021, April 15). Fact sheet: Imposing costs for harmful foreign activities by the Russian government.

U.S. Department of Commerce / BIS. (2025). Framework for Artificial Intelligence Diffusion. *Federal Register, 90* FR 4544.

U.S. Department of Justice. (2020, October 19). Six Russian GRU officers charged… [Press release].

U.S. Government Accountability Office. (2024). *Healthcare cybersecurity* (GAO-25-107755).

UnitedHealth Group. (2025). *Form 10-K for the fiscal year ended December 31, 2024*. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/731766/000073176625000063/unh-20241231.htm

Vassilev, A., Oprea, A., Fordyce, A., Anderson, H., Davies, X., & Hamin, M. (2025). *Adversarial machine learning: A taxonomy and terminology of attacks and mitigations* (NIST AI 100-2 E2025). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.AI.100-2e2025

Yin, R. K. (2018). *Case study research and applications* (6th ed.). Sage.

Appendices and declarations

Appendix A. Coding rules for the geopolitical evidence level

Level	Definition	Assignment rule	Cases concerned
A	Official state attribution or documented indictment	At least one public authority has formally attributed the operation to a state actor or its agents	NotPetya, SolarWinds, Ukrainian grid
B	Documented geopolitical context, without shared formal attribution	Institutional reports establish the context, but no formal attribution exists	None in the corpus
C	Systemic impact with no established geopolitical link	Documented incident; nothing links it to a state strategy	Change Healthcare
D	Disruption resulting from a non-cyber public decision	Regulatory, commercial or export-control measure	Rare earths, AI (computing layer)

In case of doubt between two levels, the one that presupposes the least geopolitical link is retained.

Appendix B. Main sources by case

Case	Main sources
NotPetya and Maersk	A. P. Moller-Maersk (2018); The White House (2018); U.S. Department of Justice (2020); Greenberg (2018)
SolarWinds	CERT-FR (2020); CISA (2020); SolarWinds Corporation (2020); The White House (2021)
Ukrainian power grid	CISA (2016); Lee et al. (2016); U.S. Department of Justice (2020)
Change Healthcare	U.S. GAO (2024); UnitedHealth Group (2025)
Rare earths	IEA (2025)
AI and computing	ENISA (2025, 2026b); Vassilev et al. (2025); U.S. Department of Commerce / BIS (2025); Miller & Chevalier (2026)

Appendix C. Glossary

- **CISO**: chief information security officer (French: RSSI).
- **GRC**: governance, risk and compliance.
- **ICT**: information and communication technologies.
- **IS**: information system.
- **NIS**: network and information security.
- **OT**: operational technology (industrial control systems and connected technical equipment).

Appendix D. Justification of the coding

The judgements on substitution and resilience are the author's; they should be submitted to a second coder (see 8.2).

Case	Justification by dimension
NotPetya / Maersk	High dependency: update channel of accounting software and an interconnected IT estate. Moderate concentration: software widespread mainly in Ukraine. Moderate substitution: rebuilding of the estate in a few days to a few weeks. High propagation: disruption of port and logistics operations. Low resilience: recovery tied to a copy preserved by chance (Greenberg, 2018).
SolarWinds	High dependency and concentration: monitoring platform installed at thousands of customers, with extended privileges. High substitution: replacing a monitoring tool is a project of several months (author's judgement). High propagation: customers spread across many sectors. Low resilience: late detection.

Case	Justification by dimension
Ukrainian grid	High dependency: remote control of distribution substations. Moderate concentration: three distributors with similar architectures. Moderate substitution: power restored within hours, control systems restored more slowly. Moderate propagation: about 225,000 customers. Partial resilience: manual procedures retained.
Change Healthcare	High dependency, concentration and propagation: central intermediary for payment processing and administrative healthcare operations. Substitution rated high (migration of flows, contracts and integrations); this coding is open to discussion, as some providers may have turned to other intermediaries in shorter timeframes. Low resilience: wide-ranging repercussions for care providers (U.S. GAO, 2024).
Rare earths	High dependency, concentration and propagation: China's shares along the rare earth and magnet chain (IEA, 2025). High substitution: building refining and manufacturing capacity outside China takes years (author's judgement). Partial resilience: some manufacturers reduced production rather than stopping it.
AI and computing	Indicative coding, no documented incident: high concentration and substitution (computing, models, cloud), moderate to high dependency depending on the organisation, moderate propagation, resilience to be documented.

Declarations

- **Conflicts of interest:** none.
- **Funding:** the author's own resources (Twagirumukiza).
- **Data availability:** the data come from public sources cited in the references. The coding of the cases is given in 6.1 and in Appendix A.
- **Use of generative AI tools:** AI was used for proofreading.